

Ошибки путаницы привилегий: подделка межсайтовых запросов в веб-приложениях

Кичигина Полина Евгеньевна НПИбд-01-24

15 мая 2026

Российский университет дружбы народов, Москва, Россия

- Что такое CSRF и «путаница привилегий»
- Условия успешной атаки
- Схема работы CSRF
- Почему это опасно (сравнение с XSS)
- Методы защиты
- Пример реальной уязвимости (CVE-2026-44364)
- Типичные ошибки
- Вывод

CSRF (Cross-Site Request Forgery) — атака, при которой злоумышленник заставляет браузер аутентифицированного пользователя выполнить действие на доверенном сайте без его ведома.

«Ошибка путаницы привилегий» (confused deputy): браузер не различает, кто инициировал запрос — пользователь или вредоносный сайт.

- Пользователь аутентифицирован на целевом сайте (активные сессионные cookies)
- Целевой сайт не имеет защиты от CSRF
- Злоумышленник может предсказать параметры запроса

Если все три условия выполнены — атака возможна.

1. Жертва входит в интернет-банк → получает cookies
2. Злоумышленник размещает вредоносную форму на своём сайте
3. Жертва переходит на сайт атакующего
4. Браузер автоматически отправляет поддельный запрос с cookies
5. Сервер выполняет действие (перевод денег, смена пароля)

Важно: атакующий не видит ответ сервера (атака «слепая»).

Сравнение CSRF с другими атаками

Характеристика	CSRF	XSS
Атакующий видит ответ сервера?	Нет	Да
Нужна активная сессия жертвы?	Да	Не всегда
Цель	Выполнить действие от имени жертвы	Украсть данные или выполнить код
Главная защита	CSRF-токен, SameSite	Экранирование вывода

CSRF-токены — сервер генерирует уникальное значение, форма отправляет его обратно. Золотой стандарт.

SameSite=Lax — браузер не отправляет cookies при POST-запросах с других сайтов. Просто и надёжно.

Double Submit Cookie — клиент отправляет одно значение в cookie и в теле запроса.

Проверка Referer — дополнительная мера, но легко обходится.

Пример реальной уязвимости (CVE-2026-44364)

Система: MISP Modules 3.0.7 и ранее

Проблема: отсутствие CSRF-защиты в компоненте

Возможности атакующего:

- изменение данных сессии
- выполнение действий от имени администратора

Статус: исправлено в следующих версиях

- Использование GET-запросов для изменения данных (всегда используйте POST + токены)
- Отсутствие CSRF-токенов в AJAX-запросах
- Надежда только на проверку Referer (может отсутствовать)
- Неправильная настройка SameSite для cookies

CSRF — опасная «ошибка путаницы привилегий», которая остаётся актуальной. С помощью CSRF-токенов и атрибута **SameSite=Lax** вы сможете уверенно защитить свои веб-приложения. Эти инструменты — ваши надёжные помощники, когда дело касается защиты целостности действий пользователя.